/secure/callapi — app calls the API as itself

User identity (from the agent): `kh@aktis.org` — but the API call below carries the *app's* token, not the user's.

1. Token from Google (fresh)

claim	value
aud	[https://sp4-poc-api.localtest]
azp	sp4-poc-app@shibsp4-poc.iam.gserviceaccount.com
email	sp4-poc-app@shibsp4-poc.iam.gserviceaccount.com
email_verified	true
exp	Mon Nov 02 01:02:59 UTC 2026
iat	Mon Nov 02 00:02:59 UTC 2026
iss	https://accounts.google.com
sub	115261110750122373004

raw (truncated): `eyJhbGciOiJSUzI1NiIsImtpZCI6Ijk0M2EzYTVk…`

2. API response (200) from `http://localhost:8081/api/echo`


```
{
  "ok": true,
  "validated_against": {"jwks": "https://www.googleapis.com/oauth2/v3/certs", "aud": "https://sp4-poc-api.localtest"},
  "claims": {
    "aud": "[https://sp4-poc-api.localtest]",
    "azp": "sp4-poc-app@shibsp4-poc.iam.gserviceaccount.com",
    "email": "sp4-poc-app@shibsp4-poc.iam.gserviceaccount.com",
    "email_verified": "true",
    "exp": "Mon Nov 02 01:02:59 UTC 2026",
    "iat": "Mon Nov 02 00:02:59 UTC 2026",
    "iss": "https://accounts.google.com",
    "sub": "115261110750122373004"
  }
}
```


3. Negative: API told to expect a different audience → 401


```
{"ok": false, "error": "audience mismatch: token aud=[https://sp4-poc-api.localtest], expected https://someone-else.example"}
```


back